F5

DEMO LAB · AGENTIC AI · ZERO TRUST

BIG-IP APM as MCP Gateway

Bridging modern AI agents to legacy enterprise applications with OAuth 2.1, MCP protocol mediation, and credential translation — without changing the legacy app.

OAUTH 2.1 AUTH SERVER

MCP PROTOCOL GATEWAY

CREDENTIAL TRANSLATOR

THE PROBLEM

Two worlds that don't speak the same language

AI agents demand modern auth. Legacy enterprise apps don't have it. Replacing them isn't an option.

AI AGENT WORLD

OAuth 2.1 + MCP Protocol

- Bearer JWT tokens (RFC 6750)
- Token issued by an OAuth Authorization Server
- Pre-registered OAuth client identity
- Server-Sent Events / Streamable HTTP
- Tool discovery via MCP

LEGACY ENTERPRISE

HTTP Basic Auth Only

- Username / password header (RFC 7617)
- No token concept, no scopes, no expiry
- Service accounts hard-coded in callers
- No protocol awareness for SSE / MCP
- Rewriting the app: budget, risk, time

THE GAP — without a mediator, modern agents can't safely call legacy apps

THE SOLUTION

BIG-IP APM plays three roles at once

One enforcement point handles authorization, protocol gatewaying, and credential translation — using capabilities APM already has.

01

OAUTH 2.1 AUTHORIZATION SERVER

Issue & validate tokens

- Access Policy with Logon Page validates user against APM local DB
- Token endpoint mints JWT after policy reaches Allow
- JWT signed by APM and validated locally via JWKS
- Per-Request Policy re-validates JWT on every MCP call

02

MCP PROTOCOL GATEWAY

Proxy MCP traffic

- Proxies SSE / Streamable HTTP without buffering
- Validates Bearer JWT on every tool invocation
- Centralized policy enforcement for all MCP calls
- Per-tool authorization scopes (future extension)

03

CREDENTIAL TRANSLATOR

Bearer → Basic Auth

- iRule strips Bearer JWT after APM validates it
- Injects HTTP Basic Auth header to legacy backend
- Legacy app sees a familiar Authorization header — no changes
- Service-account credentials never leave BIG-IP

ARCHITECTURE

End-to-end traffic flow

Modern auth in, legacy auth out — APM does the conversion in-line.

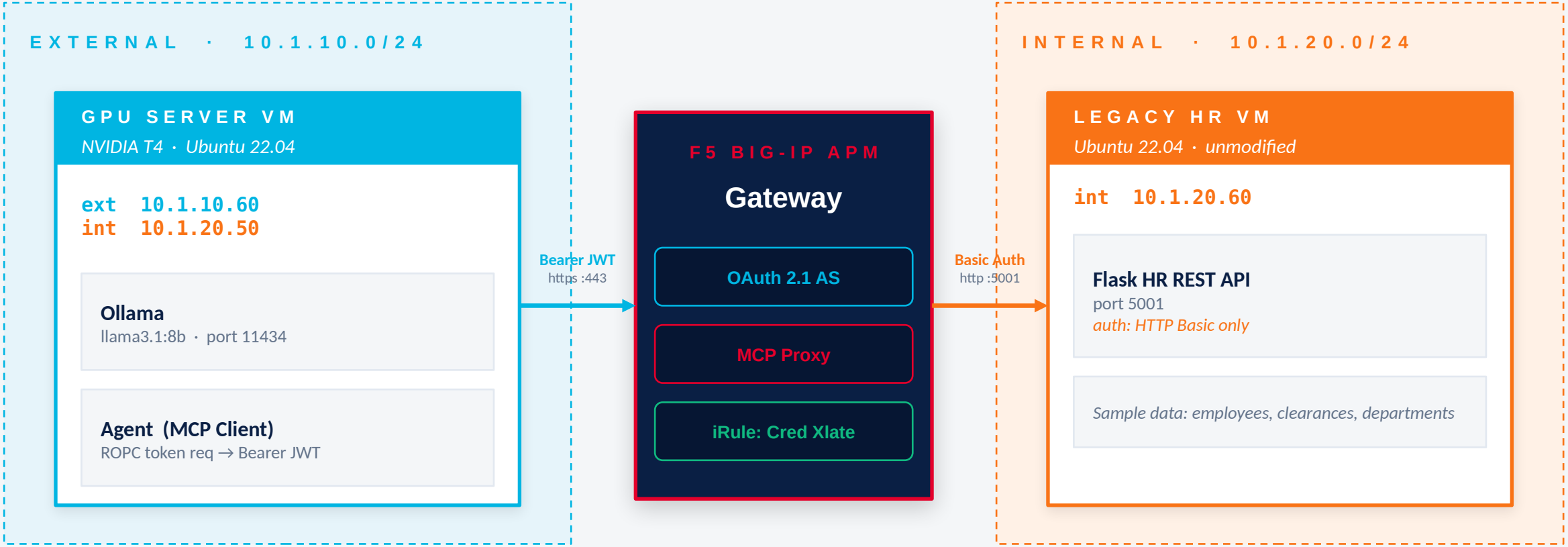
INSIDE APM

Per-Request Policy validates JWT · iRule strips Bearer header · iRule injects Basic Auth from data group · Service-account creds never traverse the agent path

LAB TOPOLOGY

How the demo is wired

Three VMs, two subnets — BIG-IP APM bridges the external (agent) and internal (legacy) zones.



Modern auth (OAuth 2.1) · Legacy auth (Basic) · Translation happens inside BIG-IP

DEMO WALKTHROUGH

What you'll see on stage

Five steps from natural-language prompt to authenticated legacy API call.

1. **Agent receives a user query**
   User asks a natural-language question; agent decides MCP tool is needed.

2. **Token acquisition (ROPC)**
   Agent POSTs username/password to /token; APM Access Policy validates via Logon Page + Local DB, issues JWT.

3. **MCP tool discovery + invocation**
   Agent calls MCP server through APM, presenting the JWT on every request.

4. **APM validates + translates**
   PRP verifies JWT, iRule swaps Bearer → Basic Auth header on the way out.

5. **Legacy app responds normally**
   HR API sees a familiar Basic Auth call, returns data, agent answers user.

SAMPLE QUERIES

Try these on the live agent

"List all employees in the cybersecurity department"

"Who has TS/SCI clearance and works in Arlington?"

"What departments does the agency have and who leads them?"

"Find information about Sarah Chen"

"How many people are on leave right now?"

"Who reports to the CISO?"

WHY F5

BIG-IP is already the right place for this

Four reasons APM is the natural enforcement point for agent-to-legacy traffic.

No application changes

The legacy HR API stays exactly as it is. APM injects Basic Auth from a service-account credential that lives only on the BIG-IP — never in the agent.

Zero Trust, applied to AI

Every MCP tool call is JWT-validated at APM. Tokens are short-lived. Per-Request Policy gives one place to revoke, audit, and scope agent access.

Built for agentic AI

Streamable HTTP and SSE pass through cleanly. APM understands MCP traffic the same way it already understands OAuth flows for human users.

Reuses what you own

If you have BIG-IP, you have an MCP gateway. No new product, no new license to negotiate. APM, iRules, and PRPs do the work.

Try the lab: github.com/therealnoof/mcp-bigip-gateway-lab